



Profa. Anelise Munaretto

Redes sem Fio — Ciência da Computação

2026

Objetivos de aprendizagem

Ao final desta aula, você será capaz de:

- **explicar** o ataque KRACK e **comparar** WPA2-PSK com WPA3-SAE;
- **descrever** a evolução WEP → WPA → WPA2 → WPA3 (criptografia e autenticação);
- **analisar** a segurança de LoRaWAN (OTAA vs. ABP) e do 5G AKA (SUCI, home control);
- **estimar** o tempo de ataque por força bruta a um PSK;
- **identificar** ameaças (*evil twin*, dicionário offline, *deauth*) e as mitigações correspondentes.

Pré-requisitos

Aulas 2 (fundamentos de redes sem fio) e 8 (IoT e redes LPWAN).

Criptografia simétrica, assimétrica e funções hash

Família	Algoritmos	Propriedade	Uso em redes sem fio
Simétrica	AES-128/256, RC4, ChaCha20	mesma chave para cifrar e decifrar	confidencialidade do tráfego (CCMP, GCMP)
Assimétrica	RSA, ECC (ECDH/ECDSA)	par de chaves (pública/privada)	troca de chaves, autenticação, SAE/Dragonfly
Hash	SHA-2, SHA-3	resumo de comprimento fixo	integridade e derivação de chaves (PBKDF2)
MAC/HMAC	HMAC-SHA256	resumo com chave secreta	autenticação de mensagens (MIC, 4-way handshake)

Criptografia simétrica, assimétrica e funções hash

Família	Algoritmos	Propriedade	Uso em redes sem fio
Simétrica	AES-128/256, RC4, ChaCha20	mesma chave para cifrar e de- cifrar	confidencialidade do tráfego (CCMP, GCMP)
Assimétrica	RSA, ECC (ECDH/ECDSA)	par de chaves (pública/privada)	troca de chaves, autenticação, SAE/Dragonfly
Hash	SHA-2, SHA-3	resumo de comprimento fixo	integridade e derivação de chaves (PBKDF2)
MAC/HMAC	HMAC-SHA256	resumo com chave secreta	autenticação de mensagens (MIC, 4-way handshake)

Três serviços, três ferramentas

- **Confidencialidade:** AES — ninguém lê o tráfego;
- **Integridade:** hash/MAC — ninguém altera sem ser detectado;
- **Autenticação:** assinatura/EAP/802.1X — quem fala é quem diz ser.

Modelo de ameaças: CIA, STRIDE e superfícies de ataque

Tríade CIA

- **Confidencialidade:** só quem deve lê;
- **Integridade:** dados não são alterados;
- **Disponibilidade:** serviço permanece acessível.

STRIDE (categorias de ameaças)

- Spoofing, Tampering, Repudiation;
- Information disclosure, Denial of service, Elevation of privilege.

Superfícies de ataque do Wi-Fi

- **Ar (RF):** sniffing passivo, injeção de frames, jamming — não há como impedir a escuta;
- **Equipamento:** firmware/backdoor, supply chain, configuração padrão;
- **Usuário:** senhas fracas, credenciais roubadas, *phishing*.

Consequência prática

O meio físico é aberto $\Rightarrow$ a confidencialidade do Wi-Fi depende *integralmente* da criptografia, não do sigilo do canal.

Evolução da segurança em Wi-Fi

Padrão	Criptografia	Autenticação	Ano
WEP	RC4 (64/128 bits)	Chave compartilhada	1999
WPA	TKIP/RC4	PSK / 802.1X	2003
WPA2	AES-CCMP	PSK / 802.1X	2004
WPA3	AES-GCMP-256	SAE (Simult. Auth. of Equals)	2018
WPA3-Enterprise	AES-GCMP-128/256	EAP-TLS, SuiteB	2018

WPA3: principais novidades

- **SAE** (Dragonfly handshake): protege contra ataques de dicionário offline
- **Perfect Forward Secrecy** (PFS)
- **PMF** (Protected Management Frames): obrigatório
- **Wi-Fi Easy Connect** (DPP): onboarding seguro

Ataques conhecidos

KRACK (2017)

- Key Reinstallation Attack (Mathy Vanhoef)
- ataque ao 4-way handshake do WPA2
- força reuso de nonce → quebra criptografia
- afeta todos os clientes WPA2
- corrigido em patches (CVE-2017-13077 a 13084)

Evil Twin / Rogue AP

- AP malicioso com mesmo SSID
- captura de credenciais (phishing)
- WPA3-Enterprise mitiga com certificado de servidor

Dicionário offline

- WPA2-PSK: capturar 4-way handshake e tentar senhas
- ferramentas: aircrack-ng, hashcat
- WPA3 SAE torna essa abordagem inviável

Deauth Attack

- envio de quadros de desautenticação falsos
- PMF obrigatório no WPA3 evita

WEP em detalhe: por que foi quebrado

Mecanismo

- Cifra de fluxo **RC4** + chave compartilhada (40 ou 104 bits);
- IV de **24 bits** transmitido em claro — apenas $2^{24} \approx 16,7$ milhões de IVs;
- integridade por **CRC-32** (ICV), que *não é autenticada*.

- ❶ **Reuso de IV**: em tráfego alto, o mesmo IV reaparece em minutos $\Rightarrow$ *keystream* reutilizado; combinando pacotes, o atacante revela os dados.
- ❷ **CRC-32 frágil**: altera-se bits do pacote e recalcula-se o CRC (sem a chave) — *bit-flipping*.
- ❸ **Ataque FMS (2001)**: a correlação entre IV e os primeiros bytes da chave de RC4 permite recuperá-la com poucos pacotes capturados.

WEP em detalhe: por que foi quebrado

Mecanismo

- Cifra de fluxo **RC4** + chave compartilhada (40 ou 104 bits);
- IV de **24 bits** transmitido em claro — apenas $2^{24} \approx 16,7$ milhões de IVs;
- integridade por **CRC-32** (ICV), que *não é autenticada*.

- ❶ **Reuso de IV**: em tráfego alto, o mesmo IV reaparece em minutos $\Rightarrow$ *keystream* reutilizado; combinando pacotes, o atacante revela os dados.
- ❷ **CRC-32 frágil**: altera-se bits do pacote e recalcula-se o CRC (sem a chave) — *bit-flipping*.
- ❸ **Ataque FMS (2001)**: a correlação entre IV e os primeiros bytes da chave de RC4 permite recuperá-la com poucos pacotes capturados.

Veredito

WEP é quebrado em **minutos** com ferramentas públicas (ex.: aircrack-ng) — motivo do banimento a partir do WPA (2003).

WPA: TKIP, os remendos do WEP

- **TKIP** (Temporal Key Integrity Protocol): ainda usa RC4, mas com correções:
 - **contador de IV** por pacote e *per-packet key mixing* $\Rightarrow$ chave efetiva diferente a cada pacote;
 - **MIC “Michael”** autentica a integridade (64 bits) — mais forte que o CRC-32;
 - *rekeying* periódico das chaves de sessão.
- **Michael é fraco** $\Rightarrow$ contramedida: se houver 2 falhas de MIC em 60s, a rede se reautentica (chaves redesenhadas).

Modos

WPA-PSK (senha compartilhada) ou **WPA-Enterprise** (802.1X). Problema: PSK humano fraco ainda permite **dicionário offline**.

Vulnerabilidades residuais

Ataques ao Michael (Beck–Tews, 2008) e força bruta offline sobre o PSK — TKIP é um paliativo, não uma solução definitiva.

WPA2: CCMP/AES e o 4-way handshake

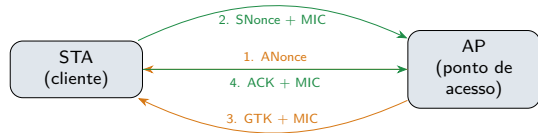
Chaves

- **PMK** (Pairwise Master Key): no PSK,

$PMK = PBKDF2(\text{senha}, \text{SSID}, 4096, 256);$

- **PTK** (Pairwise Transient Key): derivada por PRF de

$PMK + ANonce + SNonce + MAC_{AP} + MAC_{STA}.$



Papel de cada mensagem

- 1 AP → STA: **ANonce** (STA deriva o PTK);
- 2 STA → AP: **SNonce + MIC** (prova posse do PMK);
- 3 AP → STA: **GTK + MIC** (prova posse do PMK; instala chaves);
- 4 STA → AP: **ACK + MIC** (confirma a instalação).

Figura: cada mensagem autentica a posse da PMK e deriva a PTK de sessão.

KRACK (2017): reinstalação de chave no WPA2

Como funciona

- 1 o atacante bloqueia/replaya a **3ª mensagem** do handshake;
- 2 o cliente **reinstala** a mesma PTK já instalada;
- 3 reinicia os contadores (nonce) ⇒ **reuso de nonce**;
- 4 o *keystream* é reutilizado ⇒ tráfego decriptado e quadros forjados.

Impacto

Atinge WPA2 (clientes e APs), inclusive combinações com *group key* e *fast BSS transition*. Descoberta: **M. Vanhoef e F. Piessens**, ACM CCS 2017.

Contramedidas

- patches de todos os fornecedores (CVE-2017-13077 a 13084);
- **não reinstalar** a chave em mensagem repetida;
- zerar/validar nonces no processo;
- migrar para **WPA3** (SAE + PMF), imune a essa classe;
- o caso mostrou o valor da análise formal de protocolos.

Lições

Criptografia forte (AES) é inútil se o *protocolo* reusa a chave; segurança de protocolo importa tanto quanto a cifra.

SAE (Simultaneous Authentication of Equals)

- troca baseada em **curvas elípticas** (P-256) ou grupos DH;
- ambas as partes provam conhecer o segredo sem enviá-lo;
- **forward secrecy** (chaves efêmeras);
- cada tentativa exige *round-trip* com o AP
⇒ **inviabiliza o dicionário offline**.

PMF obrigatório

- *Protected Management Frames* — bloqueia *deauth* falso e MITM de frames de gestão.

OWE (RFC 8110)

- *Opportunistic Wireless Encryption* para redes abertas;
- DH efêmero sem autenticação ⇒ confidencialidade contra escuta passiva (“Enhanced Open”).

Nota

WPA3 não é imune a tudo (ex.: *downgrade* para WPA2, “dragonblood”); evite compatibilidade legada na configuração.

WPA3-Enterprise, 802.1X e EAP

Modo 192-bit

- AES-GCMP-256 para dados;
- EAP-TLS com *Suite B* 192-bit e curvas P-384;
- para organizações com requisito alto (governo, defesa).

802.1X / EAP

- **EAP-TLS**: certificados *mútuos* (servidor e cliente) — mais seguro, exige PKI;
- **PEAP**/EAP-MSCHAPv2: túnel TLS + senha — vulnerável a *evil twin* sem validação do certificado do servidor;
- o AP é *autenticador*; o RADIUS valida as credenciais.

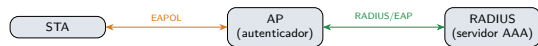


Figura: o AP apenas *autentica* (802.1X); quem decide é o RADIUS — a porta do cliente só abre após o EAP-Success.

Boas práticas

Prefira EAP-TLS (certificados) a PEAP com senha; valide o certificado do servidor para evitar *evil twin* corporativo.

Ataques clássicos de camada 2

Evil Twin

- AP falso com o **mesmo SSID**;
- usuário conecta sem perceber $\Rightarrow$ captura de credenciais, MITM.

Rogue AP

- AP não autorizado plugado na rede corporativa;
- burla firewall/802.1X e expõe a rede interna.

Deauth Attack

- quadros de desautenticação *spoofados* (MAC do AP);
- derruba clientes $\Rightarrow$ DoS ou força reconexão para capturar handshake.

Jamming

- interferência intencional no espectro;
- atinge a disponibilidade; difícil de diferenciar de ruído.

MAC spoofing

- falsificação do endereço MAC para contornar filtros de MAC;
- base para ataques de identidade.

Recado

Boa parte desses ataques é de camada 2; as defesas estão na autenticação forte (WPA3, 802.1X) e no monitoramento.

Redes abertas: sniffing e MITM

- **Sniffing**: em rede sem criptografia (*open*), qualquer pacote pode ser lido no ar — HTTP, DNS, credenciais em formulários.
- **MITM via ARP spoofing**: conectado à rede aberta, o atacante envia ARP falsos $\Rightarrow$ o tráfego das vítimas passa por ele (interceptação e modificação).
- **HTTPS ajuda, mas**: não protege contra *downgrade*, certificados inválidos ignorados, nem vazamentos por DNS em claro.

Mitigações

- **OWE** (WPA3): cifra redes abertas contra escuta passiva;
- VPN, HTTPS + HSTS;
- não confiar em redes públicas para dados sensíveis;
- validação de certificados.

WIDS (detecção)

- sensores escutam o ar em todos os canais;
- detectam *rogue AP*, *evil twin*, *deauth*, varredura de canais;
- alertam o administrador.

WIPS (prevenção)

- além de detectar, **atua**: desconecta clientes e bloqueia o AP malicioso.

Monitoramento de canais

- cobertura de espectro: detectar interferência/jamming;
- análise de sinalização 802.11;
- correlacionar com logs do controlador/AAA.

Defesa em profundidade

- WPA3 + PMF obrigatório;
- 802.1X/EAP-TLS;
- segmentação por VLAN/SSID;
- inventário e atualização de firmware.

Segurança em LoRaWAN e LPWAN

- **LoRaWAN:** criptografia AES-128 (NwkSKey, AppSKey)
 - OTAA (Over-The-Air Activation) vs. ABP (Activation By Personalization)
 - OTAA mais seguro: chaves renovadas a cada join
 - vulnerabilidade: payload pode ser descriptografado se AppSKey é exposta
- **NB-IoT / LTE-M:** segurança herdada do LTE (AES, SIM-based)
 - autenticação mútua UE-rede (AKA)
 - criptografia NAS e AS
 - chaves armazenadas no SIM

Desafio IoT

Dispositivos com recursos limitados (CPU, memória) dificultam atualizações de segurança e rotação de chaves.

Evolução do pairing

- **Legado**: PIN de 4 dígitos — fraco, sujeito a brute-force e MITM;
- **Secure Simple Pairing (SSP)**: modos *Just Works*, *numeric comparison*, *passkey entry*, *out-of-band*;
- **LE Secure Connections** (Bluetooth 4.2+): ECC P-256, resistente a escuta passiva.

Ataques notórios

- **BlueBorne** (2017): execução remota de código pelo rádio — bilhões de dispositivos;
- **BlueSmack**: DoS com pacotes L2CAP malformados;
- **KNOB** (2019): redução da entropia da chave de sessão;
- **BIAS** (2020): impersonação por falha na verificação de *link key*.

Boas práticas

Bluetooth desligado quando não usado; não ficar *discoverable*; usar *Secure Connections*; atualizar firmware (patches de BlueBorne).

Zigbee e Thread: chaves e ameaças

Chaves (IEEE 802.15.4 / Zigbee)

- **Network key:** compartilhada por toda a rede — cifra os frames;
- **Link key:** entre dois nós (par a par);
- *trust center* distribui/roda as chaves.

Thread

- comissionamento com chave *joiner* (PSKc);
- criptografia AES-128 (CCM*);
- rede mesh com foco em automação residencial.

Ameaças

- **sniffing:** frames capturados — se a network key vazar, tudo é lido;
- **replay:** retransmissão de comandos capturados (anti-replay depende de contadores bem implementados);
- **jamming** na faixa de 2,4 GHz.

Atualização segura

Muitos dispositivos têm firmware fechado e sem OTA assinado $\Rightarrow$ vulnerabilidades persistem por anos. Exigir OTA assinado e rotação de chaves.

LoRaWAN em detalhe: chaves e fluxo de segurança

Duas chaves de sessão (AES-128)

- **NwkSKey**: integridade/autenticação dos frames de rede (MIC) — *network server*;
- **AppSKey**: criptografia do payload de aplicação — *application server*.

Join OTAA

- a **AppKey** (raiz do dispositivo) deriva as chaves de sessão;
- *join-request* + *join-accept* $\Rightarrow$ chaves renovadas a cada *join*;
- contadores de frame (anti-replay) descartam frames fora de ordem.

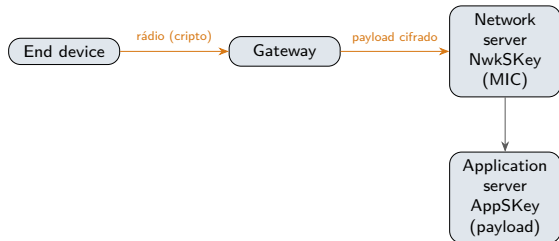


Figura: o gateway apenas encaminha; quem valida o MIC (NwkSKey) é o NS e quem decifra o payload (AppSKey) é o AS.

Limitações

Chaves de 128 bits (sem PQC),
provisionamento físico e dificuldade de rotação

5G AKA (Authentication and Key Agreement)

- evolução do EPS-AKA (4G)
- SUPI (identidade permanente) cifrado como SUCI
- *home control*: rede doméstica sempre envolvida
- chaves derivadas: K, CK, IK, K_{AMF} , etc.

Inovações de segurança 5G

- **SEPP**: proteção entre operadoras (signaling)
- **Network Slicing**: isolamento entre slices
- **MEC security**: execução confiável na borda
- **NR encryption**: AES-128/256, Snow3G, ZUC

5G AKA: SUPI vs. SUCI e o papel da rede doméstica

Identidade protegida

- **SUPI**: identidade permanente do assinante;
- **SUCI**: SUPI cifrado com a **chave pública da rede doméstica** $\Rightarrow$ **protege contra IMSI catcher**;
- o SUPI nunca trafega em claro no rádio.

Home control

- a **rede doméstica (HN)** gera os vetores de autenticação e decide;
- a rede visitada (SEAF) apenas *media* o AKA;
- derivação:
 $K \rightarrow K_{\text{AUSF}} \rightarrow K_{\text{SEAF}} \rightarrow K_{\text{AMF}} \rightarrow K_{\text{gNB}}$.

5G AKA: SUPI vs. SUCI e o papel da rede doméstica

Identidade protegida

- **SUPI**: identidade permanente do assinante;
- **SUCI**: SUPI cifrado com a **chave pública da rede doméstica** $\Rightarrow$ **protege contra IMSI catcher**;
- o SUPI nunca trafega em claro no rádio.

Home control

- a **rede doméstica (HN)** gera os vetores de autenticação e decide;
- a rede visitada (SEAF) apenas *media* o AKA;
- derivação:
 $K \rightarrow K_{\text{AUSF}} \rightarrow K_{\text{SEAF}} \rightarrow K_{\text{AMF}} \rightarrow K_{\text{gNB}}$.



Figura: no 5G AKA (TS 33.501), a rede doméstica permanece no controle (home control); o SUCI esconde a identidade.

Comparação

No 4G o IMSI podia trafegar em claro; no 5G o SUCI é usado por padrão.

SEPP (interconexão de redes)

- proxy na borda de cada operadora;
- protege a interface **N32** (roaming) contra espionagem/alteração do signaling HTTP/2;
- criptografia e assinatura das mensagens.

Tráfego de usuário

- confidencialidade e integridade no PDCP (AES-128/256, SNOW 3G, ZUC);
- integridade **obrigatória** no controle (RRC), *opcional* no plano de usuário.

Ameaças 5G

- **jamming** de pilotos/controlado (DoS físico);
- **false base station**: mitigado por autenticação mútua + SUCI;
- ataques ao **core**: interface SBI (HTTP/2/API) — exige OAuth2 e *hardening*;
- legado SS7/Diameter em *fallback* (*downgrade*);
- **supply chain**: firmware/backdoors em gNB/core.

- **Quantum computing:** ameaça a criptografia atual (RSA, ECC)
- **Supply chain:** backdoors em hardware/chipsets
- **Privacidade:** rastreamento de dispositivos (MAC aleatório, IMSI catcher)
- **Atualizações:** dispositivos IoT sem mecanismo de patch
- **Regulamentação:** Lei Geral de Proteção de Dados (LGPD), ePrivacy

Exercício resolvido — força bruta sobre um PSK

Problema: estimar o tempo para quebrar por força bruta um PSK de 8 caracteres com alfabeto de 62 símbolos (A–Z, a–z, 0–9).

① **Espaço de chaves:**

$$62^8 = 218\,340\,105\,584\,896 \approx 2,18 \times 10^{14}.$$

② **Tempo a 10^5 tentativas/s:**

$$\frac{2,18 \times 10^{14}}{10^5} = 2,18 \times 10^9 \text{ s} \approx 69,2 \text{ anos}.$$

③ **Comparação com dicionário:** com 10^8 senhas comuns a 10^5 /s, o ataque leva apenas 10^3 s $\approx$ 17 min — por isso senhas fracas são o ponto fraco do WPA2-PSK.

Por que o WPA3-SAE (Dragonfly) muda o jogo?

No SAE o segredo não é comparável offline: cada tentativa exige um *round-trip* com o AP (sujeito a *rate-limiting*), inviabilizando o ataque de dicionário offline.

Exercício: força bruta de 128 bits vs. PSK humano

- ❶ **Chave de 128 bits:** $2^{128} \approx 3,4 \times 10^{38}$ combinações. A 10^{12} tentativas/s:

$$\frac{3,4 \times 10^{38}}{10^{12}} = 3,4 \times 10^{26} \text{ s} \approx 10^{19} \text{ anos} \Rightarrow \text{inviável.}$$

- ❷ **PSK de 8 caracteres** (62 símbolos): $62^8 \approx 2,2 \times 10^{14}$; a $10^5/\text{s} \Rightarrow \approx 69$ anos (o dicionário quebra em minutos).
- ❸ **PSK de 12 caracteres:** $62^{12} \approx 3,2 \times 10^{21}$; a $10^5/\text{s} \Rightarrow \approx 10^9$ anos.

Exercício: força bruta de 128 bits vs. PSK humano

- ❶ **Chave de 128 bits:** $2^{128} \approx 3,4 \times 10^{38}$ combinações. A 10^{12} tentativas/s:

$$\frac{3,4 \times 10^{38}}{10^{12}} = 3,4 \times 10^{26} \text{ s} \approx 10^{19} \text{ anos} \Rightarrow \text{inviável.}$$

- ❷ **PSK de 8 caracteres** (62 símbolos): $62^8 \approx 2,2 \times 10^{14}$; a $10^5/\text{s} \Rightarrow \approx 69$ anos (o dicionário quebra em minutos).
- ❸ **PSK de 12 caracteres:** $62^{12} \approx 3,2 \times 10^{21}$; a $10^5/\text{s} \Rightarrow \approx 10^9$ anos.

Conclusão

A **chave criptográfica** não é o ponto fraco (128 bits são imbatíveis); a fraqueza está no **PSK humano** de baixa entropia e previsível — por isso o WPA3/SAE proíbe o teste offline.

- **Wi-Fi:** WEP (RC4) → WPA (TKIP) → WPA2 (AES-CCMP) → WPA3 (AES-GCMP, SAE).
- **WPA3-SAE:** resistente a dicionário offline, PFS e PMF obrigatório.
- **KRACK (2017):** reinstalação de chave no 4-way handshake do WPA2; corrigido por patches (CVE-2017-13077–13084).
- **Ameaças:** *evil twin*/Rogue AP, dicionário offline, *deauth* falso.
- **LoRaWAN:** AES-128 com NwkSKey/AppSKey; OTAA renova chaves a cada *join* (mais seguro que ABP).
- **5G AKA:** SUPI cifrado como SUCI, *home control*, chaves derivadas (K, CK, IK, K_{AMF}); SEPP protege o signaling entre operadoras.
- **Quantitativo:** $62^8 \approx 2,18 \times 10^{14}$; a 10^5 tentativas/s → ≈ 69 anos.

- ❶ O ataque KRACK explora:
- (a) a reinstalação da chave de sessão no 4-way handshake do WPA2
 - (b) a ausência de criptografia no WEP
 - (c) o roubo da senha no servidor RADIUS

- ❶ O ataque KRACK explora:
- (a) a reinstalação da chave de sessão no 4-way handshake do WPA2
 - (b) a ausência de criptografia no WEP
 - (c) o roubo da senha no servidor RADIUS

Gabarito: (a)

- ❷ No WPA3, o PSK é substituído pelo protocolo:
- (a) EAP-TLS
 - (b) SAE (Simultaneous Authentication of Equals)
 - (c) TKIP/RC4

- ❶ O ataque KRACK explora:
- (a) a reinstalação da chave de sessão no 4-way handshake do WPA2
 - (b) a ausência de criptografia no WEP
 - (c) o roubo da senha no servidor RADIUS

Gabarito: (a)

- ❷ No WPA3, o PSK é substituído pelo protocolo:
- (a) EAP-TLS
 - (b) SAE (Simultaneous Authentication of Equals)
 - (c) TKIP/RC4

Gabarito: (b)

- ❸ Em LoRaWAN, o modo OTAA é mais seguro que o ABP porque:
- (a) usa AES-64 em vez de AES-128
 - (b) dispensa o servidor de rede
 - (c) renova as chaves de sessão a cada *join*

- ❶ O ataque KRACK explora:
- (a) a reinstalação da chave de sessão no 4-way handshake do WPA2
 - (b) a ausência de criptografia no WEP
 - (c) o roubo da senha no servidor RADIUS

Gabarito: (a)

- ❷ No WPA3, o PSK é substituído pelo protocolo:
- (a) EAP-TLS
 - (b) SAE (Simultaneous Authentication of Equals)
 - (c) TKIP/RC4

Gabarito: (b)

- ❸ Em LoRaWAN, o modo OTAA é mais seguro que o ABP porque:
- (a) usa AES-64 em vez de AES-128
 - (b) dispensa o servidor de rede
 - (c) renova as chaves de sessão a cada *join*

Gabarito: (c)

- ❹ No 5G AKA, a identidade permanente do usuário (SUPI) é transmitida:
- (a) em texto claro no rádio

- ❶ O ataque KRACK explora:
- (a) a reinstalação da chave de sessão no 4-way handshake do WPA2
 - (b) a ausência de criptografia no WEP
 - (c) o roubo da senha no servidor RADIUS

Gabarito: (a)

- ❷ No WPA3, o PSK é substituído pelo protocolo:
- (a) EAP-TLS
 - (b) SAE (Simultaneous Authentication of Equals)
 - (c) TKIP/RC4

Gabarito: (b)

- ❸ Em LoRaWAN, o modo OTAA é mais seguro que o ABP porque:
- (a) usa AES-64 em vez de AES-128
 - (b) dispensa o servidor de rede
 - (c) renova as chaves de sessão a cada *join*

Gabarito: (c)

- ❹ No 5G AKA, a identidade permanente do usuário (SUPI) é transmitida:
- (a) em texto claro no rádio

- ① No ataque KRACK, quando o AP **retransmite** a 3ª mensagem do 4-way handshake, o cliente:
- (a) reinstala a mesma chave e reutiliza o nonce
 - (b) perde a senha do PSK em claro
 - (c) se desconecta permanentemente da rede

- ❶ No ataque KRACK, quando o AP **retransmite** a 3ª mensagem do 4-way handshake, o cliente:
- (a) reinstala a mesma chave e reutiliza o nonce
 - (b) perde a senha do PSK em claro
 - (c) se desconecta permanentemente da rede

Gabarito: (a)

- ❷ Em LoRaWAN, a **NwkSKey** é responsável por:
- (a) cifrar o payload de aplicação
 - (b) proteger a integridade/autenticação dos frames de rede (MIC)
 - (c) autenticar o dispositivo no gateway

Autoavaliação (continuação)

- ❶ No ataque KRACK, quando o AP **retransmite** a 3ª mensagem do 4-way handshake, o cliente:
- (a) reinstala a mesma chave e reutiliza o nonce
 - (b) perde a senha do PSK em claro
 - (c) se desconecta permanentemente da rede

Gabarito: (a)

- ❷ Em LoRaWAN, a **NwkSKey** é responsável por:
- (a) cifrar o payload de aplicação
 - (b) proteger a integridade/autenticação dos frames de rede (MIC)
 - (c) autenticar o dispositivo no gateway

Gabarito: (b)

Laboratório sugerido

Auditoria Wi-Fi controlada e legal

- Montar um AP de laboratório próprio (sem acesso à rede de produção) e capturar o tráfego com Wireshark em modo monitor.
- Demonstrar o **4-way handshake**: identificar as mensagens EAPOL 1–4 na captura.
- Com aircrack-ng/hashcat, testar a PSK em *wordlist* pequena para observar o ataque de dicionário offline ao WPA2-PSK.
- Repetir com WPA3 (se o AP suportar) e verificar que a captura offline não permite o mesmo ataque (SAE).

Ética e legalidade

Executar apenas em equipamentos próprios e com autorização; interferir em redes alheias viola a lei (Lei 12.737/2012 – Lei Carolina Dieckmann).

Criptografia pós-quântica: o padrão NIST 2024

Padrões publicados pelo NIST em 2024

- **FIPS 203 — ML-KEM** (baseado em *Kyber*): *key encapsulation mechanism* para troca de chaves;
- **FIPS 204 — ML-DSA** (baseado em *Dilithium*): assinaturas digitais;
- **FIPS 205 — SLH-DSA** (baseado em *SPHINCS+*): assinaturas *hash-based* (opção cautelosa).

Criptografia pós-quântica: o padrão NIST 2024

Padrões publicados pelo NIST em 2024

- **FIPS 203 — ML-KEM** (baseado em *Kyber*): *key encapsulation mechanism* para troca de chaves;
 - **FIPS 204 — ML-DSA** (baseado em *Dilithium*): assinaturas digitais;
 - **FIPS 205 — SLH-DSA** (baseado em *SPHINCS+*): assinaturas *hash-based* (opção cautelosa).
-
- **Por que importa para Wi-Fi/IoT:** o risco *collect now, decrypt later* — um computador quântico futuro decifra RSA/ECC de hoje;
 - dispositivos IoT têm vida de 10+ anos $\Rightarrow$ precisam de cripto resiliente a quantum;
 - prática atual: **troca de chaves híbrida** (ex.: X25519 + ML-KEM) — defesa imediata sem quebrar interoperabilidade.

No Wi-Fi

- senha **forte e longa** + **WPA3** (PMF habilitado);
- **desativar WPS** (PIN de 8 dígitos — ataque online e “Pixie Dust”);
- SSID próprio e **segmentado** para IoT (VLAN/SSID separado);
- manter o firmware do AP atualizado.

No geral

- atualizar firmware de todos os dispositivos;
- monitorar com WIDS/WIPS e logs de autenticação;
- usar 802.1X/EAP-TLS em redes corporativas;
- planejar rotação de chaves e certificados;
- princípio do *least privilege* e zero-trust.

Custo-benefício

As maiores vitórias vêm de ações simples: senha forte, WPS desligado e atualizações — mais eficazes que ferramentas sofisticadas.

Gestão de identidade: PKI e certificados para IoT

- **PKI**: autoridade certificadora (CA), certificados e gerenciamento de confiança — base do EAP-TLS e do mTLS;
- **Certificados para IoT**: identidade única por dispositivo (*enrollment*, RA, renovação);
- **mTLS**: cliente e servidor se autenticam mutuamente — evita que um sensor falso se passe por legítimo;
- **Rotação de chaves**: chaves e certificados com validade curta e renovação automática;
- **Revogação**: CRL/OCSP para invalidar dispositivos comprometidos.

Na prática

Em redes sem fio, a PKI integra o 802.1X (EAP-TLS), protege o SUPI (chave pública da HN) e habilita OTA assinado nos dispositivos.

- IEEE 802.11i-2004 (WPA2); Wi-Fi Alliance, WPA3 Specification v3.0
- M. Vanhoef, F. Piessens, “Key Reinstallation Attacks: Forcing Nonce Reuse in WPA2”, ACM CCS 2017
- 3GPP TS 33.501, *Security architecture and procedures for 5G system*
- LoRa Alliance, *LoRaWAN 1.1 Specification: Security*
- NIST SP 800-38B, *Recommendation for Block Cipher Modes of Operation*

Leitura recomendada

- IEEE 802.11i-2004 (WPA2) e Wi-Fi Alliance, *WPA3 Specification v3.0* — os dois padrões que definem o que vimos em sala.
- M. Vanhoef, F. Piessens, “Key Reinstallation Attacks: Forcing Nonce Reuse in WPA2”, *ACM CCS 2017* — o artigo original do KRACK.
- 3GPP TS 33.501, *Security architecture and procedures for 5G system* — especificação oficial do 5G AKA e do SUPI/SUCI.
- LoRa Alliance, *LoRaWAN 1.1 Specification: Security* — OTAA/ABP e derivação de chaves.
- NIST SP 800-38B — modos de operação de cifras de bloco (contexto do AES-GCM do WPA3).

Dica de estudo

Refaça o cálculo do exercício com senhas de 10 e 12 caracteres para ver como o espaço de chaves cresce exponencialmente.